

PRACTICAL CYBERSECURITY, PRIVACY & COMPLIANCE SERIES

HIPAA

A Practical Compliance and Security Manual for Managers and Junior Analysts

How health-information privacy, security, breach response, evidence, and oversight work in practice

Alberto (Al) Leiva

First Edition • July 2026

Inside: Privacy Rule • Security Rule • Breach Notification • Part 2 • Manager playbook • Open-source tools • Junior analyst labs • Interview preparation

Publication and Use Notice

Author: Alberto (Al) Leiva

Edition: First Edition, July 2026

Purpose: Free, practical education for managers, students, career changers, junior analysts, privacy professionals, and cybersecurity practitioners.

Educational and legal notice

This manual provides general educational information. It is not legal advice and does not replace advice from qualified counsel, privacy officers, security officers, or health-information professionals. HIPAA duties depend on facts, role, contracts, current federal regulations and guidance, state law, and other health-information rules.

Ethical and authorized use

Use technical tools and exercises only with written authorization and only with fictional, synthetic, or properly de-identified data. Never place real patient information in a public repository, training lab, demonstration, portfolio, or unapproved service. Technical skill does not create permission.

Preface

A welcoming introduction to practical HIPAA work.

HIPAA is often reduced to one sentence: do not share patient information. That is incomplete. Real HIPAA work includes understanding who is regulated, what information is protected, which uses and disclosures are allowed, how individual rights work, how electronic PHI is secured, how incidents are assessed, and how evidence proves that controls actually operate.

Managers must assign responsibility, fund reasonable safeguards, remove obstacles, review risk honestly, and make timely decisions. Junior analysts support data and system mapping, access reviews, risk analysis, policy evidence, rights requests, business associate files, incident facts, training records, and corrective actions.

This manual follows a methodology-first approach. A scanning tool can identify a weakness, but it cannot decide whether the whole risk analysis is accurate and thorough. A contract repository can store a BAA, but it cannot prove that the vendor follows it. A dashboard can show green status, but management remains responsible for what that status means.

Central lesson: HIPAA compliance is a continuing management program connecting health-information privacy, cybersecurity, workforce behavior, vendors, patient rights, incident response, and evidence.

— Alberto (Al) Leiva

How to Use This Manual

Managers should begin with Chapters 1 through 13 and use the playbook and templates as working references.

Junior analysts should study the regulatory guide, evidence, tools, fictional laboratory, portfolio projects, and interview chapter.

Technical readers should connect each technical finding to ePHI, a risk, a safeguard, an owner, review evidence, and correction.

Privacy and legal teams should verify the current HHS guidance, eCFR text, state laws, and other specialized health information rules.

Edition note: The visible chapter guide contains verified page numbers for this edition. The native Word field can be refreshed after editing by selecting Update Table, then Update entire table.

Table of Contents

Publication and Use Notice	2
Educational and legal notice	2
Ethical and authorized use	2
Preface	3
How to Use This Manual	4
Table of Contents	4
1. HIPAA Foundations	9
1.1 The HIPAA Rules	9
1.2 HIPAA is not a general health-data law	9
1.3 Current-law checkpoint	9
2. Scope, Roles, PHI, and ePHI	10
2.1 Covered entities	10
2.2 Business associates	10
2.3 PHI and ePHI	10
2.4 De-identification	11
3. Privacy Rule: Uses and Disclosures	12
3.1 Required versus permitted	12
3.2 Treatment, payment, and health care operations	12
3.3 Authorization	12
3.4 Minimum necessary	12

3.5 Special permitted disclosures	12
4. Individual Rights and Privacy Operations	13
4.1 Rights overview	13
4.2 Access is not the same as authorization	13
4.3 Defensible request file.....	13
5. Security Rule Foundations	14
5.1 General requirements	14
5.2 Required and addressable	14
5.3 Risk analysis and risk management.....	14
6. Administrative Safeguards	16
6.1 Information-system activity review.....	16
6.2 Contingency evidence	16
7. Physical and Technical Safeguards.....	17
7.1 Technical control principles.....	17
8. Breach Notification Rule	18
8.1 Breach presumption and four-factor assessment	18
8.2 Exceptions	18
9. Business Associates and Vendor Oversight.....	19
9.1 Business associate agreement contents	19
9.2 Due diligence	19
10. Part 2 and Special Health Information.....	20
10.1 42 CFR Part 2	20
10.2 Specialized and state rules	20
10.3 Reproductive-health rule status	20
11. Enforcement, State Law, and Current Developments	21
11.1 OCR enforcement	21
11.2 Penalty tiers	21
11.3 State-law preemption	21
11.4 Security Rule NPRM.....	21
11.5 Online tracking technologies.....	21
12. Complete Regulatory Requirements Guide	22
12.1 Security Rule.....	22
12.2 Privacy Rule	22
12.3 Breach Notification Rule.....	23

12.4 Enforcement and preemption	23
12.5 Compliance verification method	24
12.6 Practical verification tests	25
12.7 Evidence reliability	25
13. Manager's HIPAA Playbook	26
13.1 Questions for every owner	26
13.2 Monthly dashboard	26
13.3 Common management mistakes	26
14. From Beginner to Junior HIPAA Analyst	27
14.1 Job titles	27
14.2 Typical junior work.....	27
14.3 Portfolio proof	28
15. Open-Source Tools for HIPAA Work	29
15.1 Tool-to-requirement verification matrix	29
15.2 How to validate a tool before relying on it.....	30
15.3 Tool evidence package	31
15.4 CISO Assistant	31
Quick start	31
Evidence to retain	31
15.5 Wazuh	32
Quick start	32
Evidence to retain	32
15.6 OpenSCAP	32
Quick start	32
Evidence to retain	32
15.7 Greenbone Community Edition	32
Quick start	32
Evidence to retain	32
15.8 osquery.....	32
Quick start	33
Evidence to retain	33
15.9 Trivy	33
Quick start	33
Evidence to retain	33

15.10 OWASP ZAP	33
Quick start	33
Evidence to retain	33
15.11 Keycloak	33
Quick start	34
Evidence to retain	34
15.12 DefectDojo.....	34
Quick start	34
Evidence to retain	34
15.13 Velociraptor	34
Quick start	34
Evidence to retain	34
15.14 Open Policy Agent	34
Quick start	34
Evidence to retain	35
15.15 Free government resource	35
15.16 Tool governance checklist.....	35
16. Fictional Healthcare Laboratory and Portfolio	36
Project 1 — Scope and roles.....	36
Project 2 — Risk analysis.....	36
Project 3 — Security safeguards	36
Project 4 — Privacy rights	36
Project 5 — Breach	36
Project 6 — Vendor	36
Project 7 — Tools.....	36
16.1 Portfolio ethics.....	36
17. Thirty-Day Learning Plan.....	37
17.1 Daily habit.....	37
18. Interview Preparation	38
Who must comply with HIPAA?	38
What is PHI?.....	38
PHI versus ePHI?	38
What is minimum necessary?.....	38
What is a HIPAA risk analysis?	38

Does addressable mean optional?	38
What is the breach standard?	38
How do business associates support compliance?	38
How do you prove a safeguard works?	38
18.1 Manager's 60-second answer	39
19. Templates and Checklists	40
19.1 ePHI inventory fields	40
19.2 Risk register fields	40
19.3 Breach fact sheet	40
19.4 BAA checklist	40
19.5 Manager pre-audit checklist	41
20. Glossary	42
21. Subject Index	44
22. Official References and Further Study	45

1. HIPAA Foundations

What HIPAA covers, what it does not cover, and how its main rules work together.



HIPAA compliance connects privacy, cybersecurity, incident response, and accountability

Figure 1. The main HIPAA compliance areas

1.1 The HIPAA Rules

Area	Purpose	Primary focus
Privacy Rule	Limits uses and disclosures and gives individuals rights	PHI in electronic, paper, and oral form
Security Rule	Protects electronic PHI	Administrative, physical, and technical safeguards
Breach Notification Rule	Requires assessment and notification after certain breaches	Unsecured PHI and documented risk decisions
Enforcement Rule	Explains investigations and penalties	Complaints, compliance reviews, evidence, correction
Transactions and Code Sets	Standardizes covered electronic health transactions	Administrative simplification standards

1.2 HIPAA is not a general health-data law

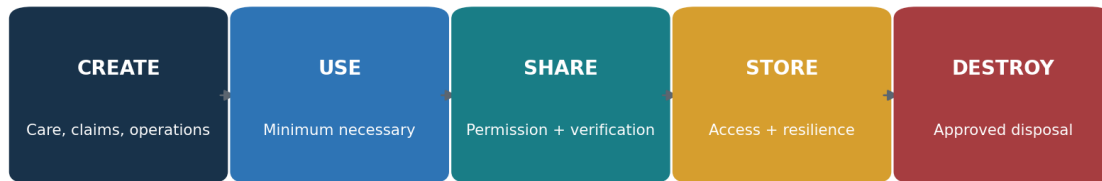
HIPAA applies to covered entities, business associates, and certain related arrangements. A fitness app, employer, school, life insurer, or direct-to-consumer service may hold sensitive health data without being a HIPAA covered entity. Other federal and state laws may still apply.

1.3 Current-law checkpoint

Important: The December 2024 HIPAA Security Rule update is a proposed rule, not the current final Security Rule. This manual explains the current rule and clearly labels the proposal as a future-development item.

2. Scope, Roles, PHI, and ePHI

How to identify regulated entities, protected information, boundaries, and responsibilities.



Map PHI and ePHI across people, devices, systems, vendors, locations, and backups

Figure 2. PHI lifecycle

2.1 Covered entities

- ✓ Health plans
- ✓ Health care clearinghouses
- ✓ Health care providers that transmit health information electronically in connection with a covered transaction

2.2 Business associates

A business associate performs certain functions or services for a covered entity involving PHI. A subcontractor that creates, receives, maintains, or transmits PHI on behalf of a business associate can also be a business associate. Status comes from the facts and rules, not merely from whether a contract is signed.

2.3 PHI and ePHI

Protected health information is individually identifiable health information held or transmitted by a covered entity or business associate, subject to exclusions such as certain education and employment records. ePHI is PHI maintained or transmitted electronically. The Security Rule protects ePHI; the Privacy Rule protects PHI in any form.

2.4 De-identification

Method	Plain meaning	Evidence
Expert determination	A qualified expert determines and documents that identification risk is very small	Expert qualifications, method, assumptions, report
Safe Harbor	Remove the listed identifiers and have no actual knowledge that remaining information identifies a person	Identifier checklist, quality review, approval

Manager checkpoint: Require a written scope and role analysis for each legal entity, service, product, employer function, research activity, vendor, and data flow.

3. Privacy Rule: Uses and Disclosures

Permitted uses, authorizations, minimum necessary, verification, notices, and special situations.

3.1 Required versus permitted

The Privacy Rule requires disclosure to the individual in certain rights situations and to HHS for enforcement. It permits many other uses and disclosures when conditions are met. A permitted disclosure is not always mandatory; other laws and professional duties may affect the decision.

3.2 Treatment, payment, and health care operations

Covered entities may use and disclose PHI for treatment, payment, and health care operations under the rule. Teams must still confirm the purpose, recipient, role, applicable minimum-necessary rule, notices, and other conditions.

3.3 Authorization

- ✓ Describe the information in a specific and meaningful way.
- ✓ Name or describe who may disclose and receive it.
- ✓ State the purpose, expiration, and required statements.
- ✓ Use plain language and obtain signature and date.
- ✓ Track revocation and reliance already taken.
- ✓ Apply special rules for psychotherapy notes, marketing, and sale of PHI.

3.4 Minimum necessary

When the minimum-necessary standard applies, limit uses, disclosures, and requests to the PHI reasonably needed for the purpose. Define workforce roles, routine protocols, nonroutine review, and reasonable reliance. The standard has exceptions, including disclosures to or requests by a health care provider for treatment.

3.5 Special permitted disclosures

Situation	Required analysis
Required by law	Identify the exact legal requirement and limit the disclosure
Public health	Verify recipient authority and permitted purpose
Abuse, neglect, or domestic violence	Apply conditions, safety considerations, and notice rules
Health oversight	Confirm oversight authority and scope
Judicial or administrative proceeding	Review order, subpoena, notice, protective-order, and objection conditions
Law enforcement	Identify the precise permission and verify the requester
Research	Confirm authorization, waiver, preparatory review, or decedent conditions
Serious threat	Apply good-faith and applicable-law conditions
Workers' compensation	Limit disclosure to what the law authorizes

4. Individual Rights and Privacy Operations

How to receive, verify, complete, and document patient and member requests.

4.1 Rights overview

Right	Typical deadline	Operational work
Notice of privacy practices	At required service, enrollment, posting, and revision points	Current notice, distribution, acknowledgment, website
Access	Generally 30 days; one 30-day extension with timely written notice	Verify, search designated record set, review exclusions, format, fees, delivery
Amendment	Generally 60 days; one 30-day extension with notice	Review, accept or deny, link records, notify parties
Accounting of disclosures	Generally 60 days; one 30-day extension with notice	Search disclosure logs, apply exceptions, deliver accounting
Restriction request	Review and respond; certain paid-in-full health-plan restrictions must be accepted	Decision, system flag, downstream control
Confidential communications	Accommodate reasonable requests under the applicable rule	Alternate address, channel, safety handling
Complaint	No retaliation; process under policy	Log, investigate, respond, mitigate, retain evidence

4.2 Access is not the same as authorization

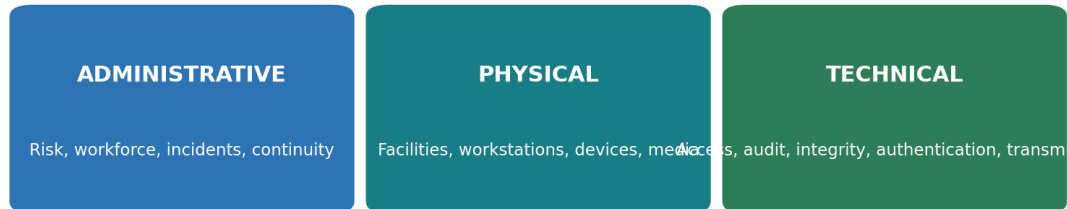
An individual's right of access under 45 CFR 164.524 has its own scope, timing, denial, format, and fee rules. Do not automatically apply an authorization process or create barriers that the access rule does not allow.

4.3 Defensible request file

- ✓ Request and receipt date
- ✓ Identity and personal-representative decision
- ✓ Designated record set and systems searched
- ✓ Exclusions, reviewable denial, and legal analysis
- ✓ Format, delivery method, and fee calculation
- ✓ Extension notice when used
- ✓ Response, delivery proof, and completion date

5. Security Rule Foundations

General requirements, flexibility, required and addressable specifications, and evidence.



All safeguards depend on an accurate and thorough risk analysis

Figure 3. HIPAA Security Rule safeguards

5.1 General requirements

Ensure confidentiality, integrity, and availability of ePHI.
 Protect against reasonably anticipated threats and hazards.
 Protect against reasonably anticipated impermissible uses or disclosures.
 Ensure workforce compliance.

5.2 Required and addressable

Addressable does not mean optional: For an addressable specification, assess whether it is reasonable and appropriate. Implement it when it is. If it is not, document why and implement an equivalent reasonable and appropriate alternative when one exists.

5.3 Risk analysis and risk management

1. Define all ePHI and regulated-entity boundaries.
2. Map systems, applications, devices, people, locations, vendors, networks, interfaces, backups, and media.
3. Identify threats, vulnerabilities, existing measures, likelihood, and impact.
4. Determine risk consistently.
5. Assign treatments, owners, resources, dates, and acceptance authority.

6. Retest and update after changes, incidents, new threats, and control failures.

The current Security Rule does not set one fixed risk-analysis frequency. HHS guidance states the process should be ongoing and updated as needed.

6. Administrative Safeguards

The management processes that turn policy into repeatable protection.

Citation	Standard	Manager action	Evidence
164.308(a)(1)	Security management process	Perform risk analysis, risk management, sanctions, and information-system activity review.	Risk analysis, treatment plan, sanctions, log-review evidence
164.308(a)(2)	Assigned security responsibility	Designate the official responsible for Security Rule policies and procedures.	Role description, appointment, reporting line
164.308(a)(3)	Workforce security	Authorize, supervise, clear, and promptly remove workforce access.	Access approvals, screening, termination evidence
164.308(a)(4)	Information access management	Control access based on role and need, including establishment and modification.	Access matrix, approvals, periodic reviews
164.308(a)(5)	Security awareness and training	Train the workforce and address reminders, malware, log-in monitoring, and password management.	Training, simulations, reminders, follow-up
164.308(a)(6)	Security incident procedures	Identify, respond to, mitigate, document, and report incidents.	Incident plan, tickets, evidence, lessons
164.308(a)(7)	Contingency plan	Operate backups, disaster recovery, emergency mode, testing, and criticality analysis.	Backup reports, restore tests, exercises, recovery plans
164.308(a)(8)	Evaluation	Perform periodic technical and nontechnical evaluation after relevant changes.	Evaluation scope, findings, correction plan
164.308(b)	Business associate arrangements	Use contracts or other arrangements that require appropriate safeguards.	BAA, due diligence, monitoring

6.1 Information-system activity review

Define which audit logs, access reports, security events, exception reports, and alerts are reviewed; how often; by whom; how evidence is retained; and how suspicious activity becomes an incident or corrective action.

6.2 Contingency evidence

- ✓ Backup job and failure reports
- ✓ Offline or otherwise protected backup design
- ✓ Documented restore tests
- ✓ Emergency-mode procedures
- ✓ Disaster-recovery exercises
- ✓ Critical application and data analysis
- ✓ Lessons, owners, and due dates

7. Physical and Technical Safeguards

Facilities, workstations, media, identity, access, audit, integrity, and transmission controls.

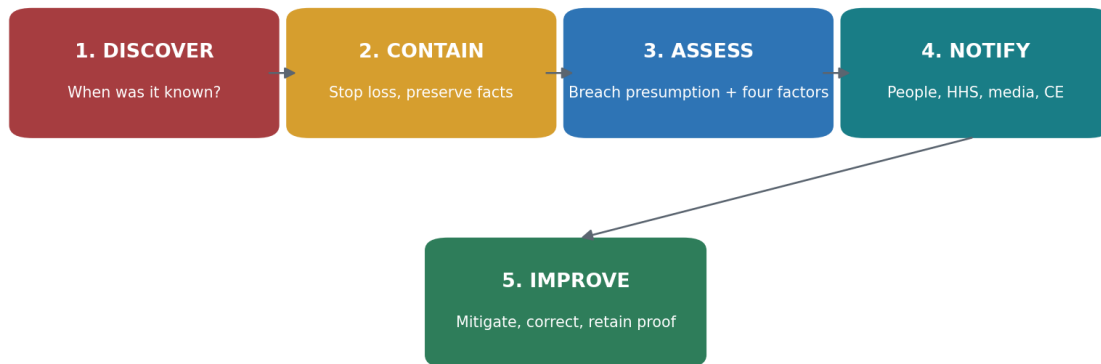
Citation	Standard	Manager action	Evidence
164.310(a)	Facility access controls	Limit physical access while allowing authorized access and continuity.	Facility plan, visitor logs, maintenance records
164.310(b)	Workstation use	Define proper functions and physical surroundings for workstations using ePHI.	Workstation policy, training, observations
164.310(c)	Workstation security	Restrict physical access to workstations that access ePHI.	Secure locations, screens, device controls
164.310(d)	Device and media controls	Control receipt, movement, reuse, backup, disposal, and accountability.	Inventory, chain of custody, wiping and destruction proof
164.312(a)	Access control	Use unique IDs, emergency access, and suitable logoff and encryption controls.	IAM settings, emergency test, encryption record
164.312(b)	Audit controls	Record and examine activity in systems containing or using ePHI.	Logs, review schedule, investigation records
164.312(c)	Integrity	Protect ePHI from improper alteration or destruction.	Integrity checks, change controls, validation
164.312(d)	Person or entity authentication	Verify that a person or entity seeking access is the one claimed.	Authentication settings, MFA, identity records
164.312(e)	Transmission security	Protect ePHI against unauthorized access while transmitted.	Encryption, secure protocols, architecture tests
164.314	Organizational requirements	Address business associate contracts and group health plan requirements.	Contracts, plan documents, reviews
164.316	Policies, procedures, and documentation	Implement reasonable policies and retain required documentation for six years.	Approved policies, versions, six-year retention evidence

7.1 Technical control principles

- ✓ Give every user a unique identity.
- ✓ Use least privilege and timely removal.
- ✓ Protect privileged and emergency access.
- ✓ Record meaningful activity and review it.
- ✓ Use strong authentication suitable for risk.
- ✓ Protect ePHI at rest and in transit based on the documented analysis.
- ✓ Test integrity, recovery, and control effectiveness.
- ✓ Manage exceptions with owner, reason, compensating controls, expiry, and approval.

8. Breach Notification Rule

How to assess unsecured PHI incidents and meet notification duties.



Notification deadlines are maximum limits; the rules also require action without unreasonable delay.

Figure 4. HIPAA breach workflow

8.1 Breach presumption and four-factor assessment

An impermissible use or disclosure of PHI is presumed to be a breach unless the covered entity or business associate demonstrates a low probability that the PHI was compromised. Assess at least the nature and extent of PHI and likelihood of re-identification, the unauthorized person, whether PHI was actually acquired or viewed, and the extent of mitigation.

Notification	Timing overview	Evidence
Individuals	Without unreasonable delay and no later than 60 days after discovery	Content, delivery, substitute notice, proof
HHS — 500 or more	Under the rule's contemporaneous reporting timing	HHS submission and affected count
HHS — fewer than 500	Annual reporting, no later than 60 days after the end of the calendar year	Small-breach log and submission
Media	More than 500 residents of a state or jurisdiction	Jurisdiction count, media notice
Business associate to covered entity	Without unreasonable delay and no later than 60 days	Discovery date, identities if known, facts and notice

8.2 Exceptions

The breach definition contains narrow exceptions involving certain unintentional or inadvertent workforce access and good-faith beliefs that an unauthorized recipient could not reasonably retain the information. Document facts and legal review before relying on an exception.

9. Business Associates and Vendor Oversight

Contracts, subcontractors, due diligence, monitoring, incidents, and termination.

9.1 Business associate agreement contents

Permitted and required uses and disclosures
 No use or disclosure beyond the contract or law
 Appropriate safeguards and Security Rule compliance for ePHI
 Breach, incident, and unsecured-PHI reporting
 Support for access, amendment, and accounting duties
 PHI availability for HHS compliance review
 Return or destruction at termination when feasible
 Subcontractor agreements with the same applicable restrictions
 Termination rights for material violation

9.2 Due diligence

Area	Questions	Evidence
Scope	What PHI/ePHI, purpose, services, locations, and interfaces?	Data flow, inventory, architecture
Security	Risk analysis, encryption, identity, logging, vulnerability, backups, incident response?	Policies, tests, reports, remediation
Privacy	Minimum necessary, workforce access, rights support, disclosure controls?	Procedures, roles, samples
Subcontractors	Who, where, for what purpose, under what agreement?	Subprocessor list and terms
Incidents	When and how will the BA report and cooperate?	BAA, exercise, contacts
Exit	How will access end and PHI be returned or destroyed?	Exit plan, deletion proof, residual-risk record

Management point: A signed BAA is necessary in many relationships, but it does not replace due diligence, risk management, access control, monitoring, or incident coordination.

10. Part 2 and Special Health Information

Substance use disorder records, mental health, genetics, and other overlapping rules.

10.1 42 CFR Part 2

The 2024 Part 2 Final Rule became effective April 16, 2024, and compliance was required by February 16, 2026. It aligns important consent, enforcement, breach-notification, and notice provisions more closely with HIPAA while retaining special protections for records of federally assisted substance use disorder programs.

Determine whether the organization is a Part 2 program, lawful holder, or recipient.

Use the current Part 2 consent, redisclosure, complaint, breach, and notice requirements.

Do not assume that HIPAA permission alone always resolves Part 2 duties.

Update notices of privacy practices and Part 2 patient notices as required for February 16, 2026 compliance.

10.2 Specialized and state rules

State law may be more stringent than HIPAA and may impose special rules for mental health, HIV, reproductive health, genetics, minors, telehealth, biometric data, or breach notice. Other federal rules can apply to substance use disorder records, education records, clinical research, information blocking, consumer health apps, and sensitive-data transfers.

10.3 Reproductive-health rule status

Current status: A federal district court order dated June 18, 2025 vacated most of the 2024 HIPAA reproductive-health privacy rule. HHS states that only certain Notice of Privacy Practices modifications remained. Verify the current HHS page and legal advice before using any 2024 attestation or reproductive-health workflow.

11. Enforcement, State Law, and Current Developments

Complaints, investigations, penalties, preemption, court decisions, and proposed changes.

11.1 OCR enforcement

- ✓ Receive and investigate complaints.
- ✓ Conduct compliance reviews and audits.
- ✓ Request records and cooperation.
- ✓ Seek voluntary compliance and corrective action.
- ✓ Enter resolution agreements and corrective-action plans.
- ✓ Impose civil money penalties where authorized.
- ✓ Refer possible criminal violations to the Department of Justice.

11.2 Penalty tiers

Civil penalty analysis considers knowledge, reasonable cause, willful neglect, correction, nature and extent, harm, history, financial condition, and other factors. Dollar amounts are adjusted periodically. Verify current HHS and Federal Register amounts instead of relying on an old chart.

11.3 State-law preemption

HIPAA generally preempts contrary state law, but the rules contain exceptions, including for certain more stringent privacy protections and public-health or reporting laws. Maintain a state-law matrix and obtain legal review for each service location and individual population.

11.4 Security Rule NPRM

HHS proposed major Security Rule changes in a notice published January 6, 2025, including more specific asset inventory, network mapping, risk analysis, testing, encryption, multifactor authentication, segmentation, recovery, and business-associate verification duties. As of this manual's July 2026 publication, official HHS materials continue to identify it as a proposed rule. Monitor it, plan readiness, but do not describe proposed text as current final law.

11.5 Online tracking technologies

HHS notes that a court vacated part of its tracking-technology guidance concerning an IP address combined with a visit to an unauthenticated public webpage about health conditions or providers. Inventory tracking technologies, verify actual data and context, review contracts and disclosures, and use current legal guidance rather than broad assumptions.

12. Complete Regulatory Requirements Guide

A practical cross-reference to current Privacy, Security, and Breach Notification requirements.

12.1 Security Rule

Citation	Requirement	Manager action	Typical evidence
164.306	General rules	Protect ePHI confidentiality, integrity, and availability; address anticipated threats and impermissible uses.	Security program, risk decisions, flexibility analysis
164.308(a)(1)	Security management process	Perform risk analysis, risk management, sanctions, and information-system activity review.	Risk analysis, treatment plan, sanctions, log-review evidence
164.308(a)(2)	Assigned security responsibility	Designate the official responsible for Security Rule policies and procedures.	Role description, appointment, reporting line
164.308(a)(3)	Workforce security	Authorize, supervise, clear, and promptly remove workforce access.	Access approvals, screening, termination evidence
164.308(a)(4)	Information access management	Control access based on role and need, including establishment and modification.	Access matrix, approvals, periodic reviews
164.308(a)(5)	Security awareness and training	Train the workforce and address reminders, malware, log-in monitoring, and password management.	Training, simulations, reminders, follow-up
164.308(a)(6)	Security incident procedures	Identify, respond to, mitigate, document, and report incidents.	Incident plan, tickets, evidence, lessons
164.308(a)(7)	Contingency plan	Operate backups, disaster recovery, emergency mode, testing, and criticality analysis.	Backup reports, restore tests, exercises, recovery plans
164.308(a)(8)	Evaluation	Perform periodic technical and nontechnical evaluation after relevant changes.	Evaluation scope, findings, correction plan
164.308(b)	Business associate arrangements	Use contracts or other arrangements that require appropriate safeguards.	BAA, due diligence, monitoring
164.310(a)	Facility access controls	Limit physical access while allowing authorized access and continuity.	Facility plan, visitor logs, maintenance records
164.310(b)	Workstation use	Define proper functions and physical surroundings for workstations using ePHI.	Workstation policy, training, observations
164.310(c)	Workstation security	Restrict physical access to workstations that access ePHI.	Secure locations, screens, device controls
164.310(d)	Device and media controls	Control receipt, movement, reuse, backup, disposal, and accountability.	Inventory, chain of custody, wiping and destruction proof
164.312(a)	Access control	Use unique IDs, emergency access, and suitable logoff and encryption controls.	IAM settings, emergency test, encryption record
164.312(b)	Audit controls	Record and examine activity in systems containing or using ePHI.	Logs, review schedule, investigation records
164.312(c)	Integrity	Protect ePHI from improper alteration or destruction.	Integrity checks, change controls, validation
164.312(d)	Person or entity authentication	Verify that a person or entity seeking access is the one claimed.	Authentication settings, MFA, identity records
164.312(e)	Transmission security	Protect ePHI against unauthorized access while transmitted.	Encryption, secure protocols, architecture tests
164.314	Organizational requirements	Address business associate contracts and group health plan requirements.	Contracts, plan documents, reviews
164.316	Policies, procedures, and documentation	Implement reasonable policies and retain required documentation for six years.	Approved policies, versions, six-year retention evidence

12.2 Privacy Rule

Citation	Requirement	Plain meaning	Typical evidence
164.502	General use and disclosure rules	Use or disclose PHI only as required or permitted; apply business associate and deceased-person rules.	Use/disclosure matrix, approvals, disclosure records
164.504	Organizational requirements	Address hybrid entities, affiliated groups, business associates, and plan-sponsor boundaries.	Designations, BAA, plan documents, firewalls
164.506	Treatment, payment, and operations	Allows defined TPO uses and disclosures and related consent practices.	TPO purpose map, notice, role access
164.508	Authorizations	Require a valid written authorization for uses and disclosures not otherwise permitted, including special authorization rules.	Authorization form, revocation, disclosure proof

Citation	Requirement	Plain meaning	Typical evidence
164.510	Opportunity to agree or object	Covers facility directories and involvement in care or payment after giving a suitable opportunity where required.	Preference record, identity and relationship check
164.512	Uses and disclosures without authorization or opportunity	Permits specific activities such as required-by-law, public health, oversight, judicial, law-enforcement, research, and serious-threat situations when conditions are met.	Legal basis, request, verification, approval, disclosure log
164.514	Other use and disclosure requirements	Covers de-identification, re-identification codes, minimum necessary, limited data sets, data use agreements, fundraising, and verification.	Method, expert determination, DUA, verification, minimum-necessary review
164.520	Notice of privacy practices	Requires a clear notice describing uses, disclosures, duties, rights, complaints, and contacts.	Current NPP, distribution, acknowledgment, website
164.522	Requests for privacy protection	Covers restrictions and confidential communications, including required acceptance of certain paid-in-full restrictions to health plans.	Request, decision, system flag, communication method
164.524	Access	Provides access to PHI in a designated record set, generally within 30 days, subject to exclusions, denial rules, format, and permitted fees.	Request log, search, denial review, delivery, fee calculation
164.526	Amendment	Lets individuals request amendment; requires decisions, notices, statements of disagreement, and record linking.	Request, decision, amendment or denial, notifications
164.528	Accounting of disclosures	Requires an accounting of certain disclosures during the applicable six-year period, with exceptions.	Disclosure log, request, accounting, response date
164.530	Administrative requirements	Requires privacy personnel, training, safeguards, complaints, sanctions, mitigation, nonretaliation, policies, and documentation.	Role appointment, training, complaints, sanctions, policies
164.532–535	Transition and compliance provisions	Addresses transition rules and compliance dates.	Legal register, transition decision, dated approval

12.3 Breach Notification Rule

Citation	Requirement	Plain meaning	Typical evidence
164.400	Applicability	Applies the breach-notification subpart to covered entities and business associates.	Scope and role analysis
164.402	Definitions and breach risk assessment	A breach of unsecured PHI is presumed unless the entity shows a low probability of compromise using the required factors.	Four-factor assessment, facts, mitigation, approval
164.404	Notice to individuals	Notify affected individuals without unreasonable delay and no later than 60 days after discovery; meet content and delivery rules.	Notification, address search, delivery and substitute notice
164.406	Notice to media	For breaches affecting more than 500 residents of a state or jurisdiction, notify prominent media within the required period.	Count by jurisdiction, media notice, delivery proof
164.408	Notice to the Secretary	Report breaches to HHS under the timing rules for 500 or more and fewer than 500 individuals.	HHS submission, annual small-breach log
164.410	Notice by a business associate	A BA must notify the covered entity without unreasonable delay and no later than 60 days, with available identification and facts.	BA notice, discovery date, affected-person information
164.412	Law-enforcement delay	Delay notice when a qualified law-enforcement statement meets the rule.	Written or oral request record and delay calculation
164.414	Administrative requirements and burden of proof	Apply workforce training, policies, nonretaliation, documentation, and proof that notices were made or not required.	Policies, training, risk assessment, notification evidence

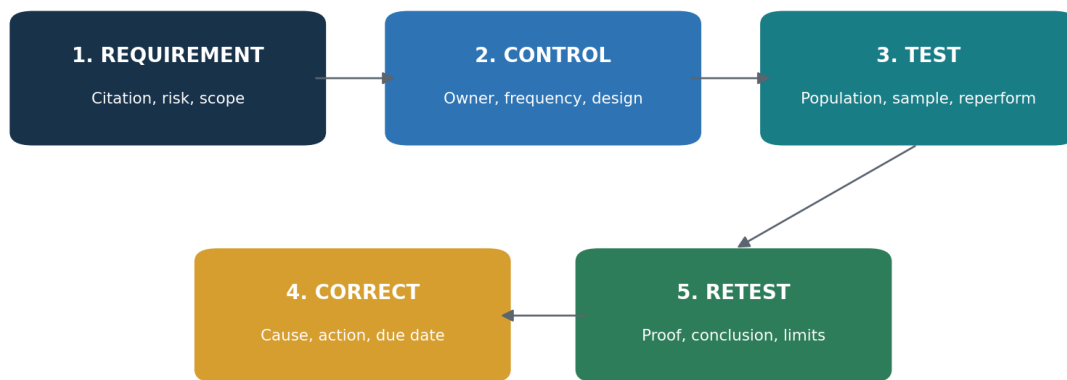
12.4 Enforcement and preemption

Citation area	Focus	Manager action	Evidence
45 CFR Part 160 Subpart B	Preemption of state law	Maintain legal matrix and escalation path	State-law review, counsel decision
Part 160 Subpart C	Compliance and investigations	Cooperate, preserve facts, avoid retaliation	Complaint and response file

Citation area	Focus	Manager action	Evidence
Part 160 Subparts D–E	Civil money penalties and procedures	Correct promptly and manage response	Findings, corrective action, hearing file

12.5 Compliance verification method

A verification test should connect a requirement to actual operations and reliable evidence. It should not begin with a screenshot or a tool report. Begin with the risk, regulated entity, ePHI boundary, requirement, and control that management says is operating.



A defensible conclusion links the rule to complete evidence and a verified correction

Figure 6. Compliance verification cycle

- ✓ Define the requirement, risk, control, owner, frequency, systems, period, and expected evidence.
- ✓ Obtain the complete population for the period and test whether it is complete and accurate.
- ✓ Select a risk-based sample that covers relevant times, systems, locations, owners, and unusual items.
- ✓ Inspect evidence and, where practical, reperform or independently confirm the control result.
- ✓ Record exceptions with the exact requirement, facts, cause, affected ePHI, duration, likelihood, and impact.
- ✓ Assign corrective action, owner, due date, interim protection, and escalation.
- ✓ Retest the correction and confirm it works across the affected population, not only for one example.
- ✓ Write a conclusion that states scope, period, work performed, result, exceptions, and limitations.

12.6 Practical verification tests

Control area	Population and sample	Test procedure	Evidence and conclusion
Terminated access	All workforce terminations in the period; sample higher-risk and ordinary departures	Compare HR termination time with account, badge, remote-access, email, EHR, and privileged-access disablement; inspect exceptions	Complete HR list, IAM and system logs, tickets, approvals, disablement time, exception and retest
Periodic access review	All required reviews by system and period; sample systems with ePHI and privileged roles	Confirm complete user population, qualified reviewer, role need, decisions, removals, completion date, and follow-up	User export, reviewer evidence, removal tickets, late-item follow-up, conclusion
Information-system activity review	All scheduled daily, weekly, or monthly reviews; sample across the period	Inspect source logs, alert coverage, reviewer identity, investigation, escalation, and retained proof	SIEM report, review record, ticket, decision, unresolved gap
Vulnerability management	All in-scope assets and findings; select critical, high, aged, and accepted findings	Confirm scan coverage and credentials, validate findings, compare deadlines, inspect correction, and rescan	Asset inventory, scan settings, report, ticket, exception, rescan, residual risk
Backups and recovery	All backup jobs and required restore tests; sample success, failure, and recovery events	Inspect job status, failure alerts, response, protected copies, restore evidence, recovery objective, and lessons	Backup logs, alert ticket, restore output, exercise record, corrective action
Security incidents and breaches	Complete incident population reconciled to alerts, help desk, privacy, and breach logs	Test classification, containment, four-factor assessment, notification timing, mitigation, and closure	Incident file, risk assessment, notices, approval, corrective action, retest
Business associates	Complete vendor and BA population; sample high-risk, new, changed, and terminated vendors	Verify status, BAA terms, due diligence, subcontractors, security evidence, incidents, changes, and exit	Vendor inventory, BAA, assessment, findings, monitoring, destruction or return proof
Individual rights	All access, amendment, restriction, confidential-communication, accounting, and complaint requests	Test identity, scope, search, deadlines, extension, denial review, fee, delivery, and retained result	Request log, search evidence, response, delivery proof, exception and conclusion
Training and sanctions	Complete workforce and contractor population; sample roles, new hires, late learners, and incidents	Compare assignments with workforce population, test completion timing, content, follow-up, and sanctions when applicable	Roster, completion report, reminders, sanction record, management review

12.7 Evidence reliability

Evidence quality	Meaning	Analyst response
Weak	Verbal statement, undated screenshot, partial export, or owner-created summary without source proof	Request source data, date, scope, system identity, reviewer, and complete population
Useful	Dated system report tied to the correct scope and period	Confirm configuration, completeness, access, and interpretation
Strong	System-generated result plus independent review, decisions, tickets, correction, and retest	Trace the full chain and record any limitation

Verification rule: A tool finding is an input, not a conclusion. Compliance verification requires scope, complete data, human review, legal and policy context, corrective action, and evidence that the control works over time.

13. Manager's HIPAA Playbook

Questions, dashboards, meetings, and decisions managers should control.

13.1 Questions for every owner

- ✓ What PHI or ePHI is involved?
- ✓ Which covered entity or business associate role applies?
- ✓ What use, disclosure, or access is permitted and necessary?
- ✓ Where does the information flow and remain?
- ✓ Who has access and who reviews it?
- ✓ What threats and vulnerabilities affect it?
- ✓ What safeguard applies and where is the evidence?
- ✓ What vendors and subcontractors are involved?
- ✓ How will rights, incidents, and deletion work?
- ✓ Who accepts residual risk and by what authority?

13.2 Monthly dashboard

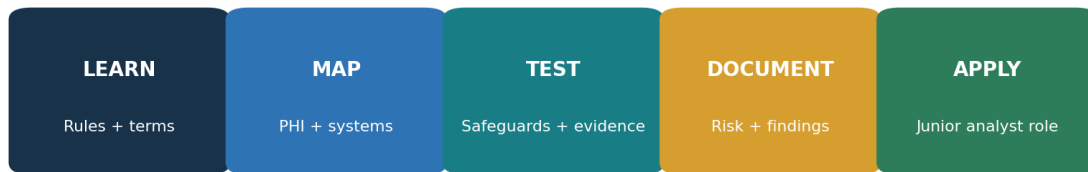
Area	Manager question	Status
Risk analysis	Are all ePHI, systems, locations, and changes covered?	Green / Yellow / Red
Risk treatment	Are high risks assigned, funded, and on schedule?	Green / Yellow / Red
Access	Were onboarding, changes, reviews, and termination completed?	Green / Yellow / Red
Activity review	Are logs and alerts reviewed with evidence?	Green / Yellow / Red
Vulnerabilities	Are findings validated, prioritized, fixed, and retested?	Green / Yellow / Red
Backups	Did backups and restore tests succeed?	Green / Yellow / Red
Incidents	Were facts, breach decisions, and notices timely?	Green / Yellow / Red
Vendors	Are BAAs, due diligence, incidents, and exits controlled?	Green / Yellow / Red
Rights	Are requests complete, accurate, secure, and timely?	Green / Yellow / Red

13.3 Common management mistakes

- ✓ Treating HIPAA as a yearly training event.
- ✓ Limiting risk analysis to the electronic health record.
- ✓ Calling addressable specifications optional.
- ✓ Signing a BAA without monitoring the vendor.
- ✓ Ignoring medical devices, cloud platforms, backups, interfaces, and remote support.
- ✓ Running scans without validating, correcting, and retesting findings.
- ✓ Delaying incident escalation until every fact is known.
- ✓ Using proposed Security Rule text as if it were final.
- ✓ Ignoring more stringent state requirements.

14. From Beginner to Junior HIPAA Analyst

A safe, honest path to entry-level privacy, security, and compliance work.



A good portfolio shows safe practice, complete evidence, and clear communication

Figure 5. Junior HIPAA analyst pathway

14.1 Job titles

Junior HIPAA Compliance Analyst
 Healthcare GRC Analyst
 Privacy Operations Analyst
 Information Security Compliance Analyst
 Third-Party Risk Analyst — Healthcare
 Health Information Privacy Analyst
 Security Risk Analyst
 HIPAA Program Coordinator

14.2 Typical junior work

- ✓ Update PHI, ePHI, system, device, and vendor inventories.
- ✓ Gather risk-analysis and safeguard evidence.
- ✓ Review access, termination, training, log, backup, and vulnerability samples.
- ✓ Track BAAs, due diligence, corrective actions, and expiry dates.
- ✓ Coordinate individual rights and disclosure records.
- ✓ Prepare incident timelines and breach-assessment facts.
- ✓ Write clear findings without making unsupported legal conclusions.
- ✓ Follow up on remediation and retain retest proof.

14.3 Portfolio proof

Skill	Fictional portfolio item
Scoping	Covered-entity and business-associate role memo
Data mapping	ePHI lifecycle, system inventory, and data-flow diagram
Risk	Risk analysis and treatment register
Security	Safeguard matrix with evidence samples
Privacy	Access-request and disclosure-accounting files
Incident response	Breach four-factor assessment and notification decision
Vendor risk	BAA checklist, due diligence, and corrective-action plan
Management communication	One-page dashboard and executive risk summary

Career honesty: A laboratory portfolio is training work, not professional experience. Label it as fictional, protect all information, and explain what required expert or legal review.

15. Open-Source Tools for HIPAA Work

Official links, safe quick starts, evidence, and limitations.

Methodology first: A tool can support a safeguard or evidence process. It cannot certify HIPAA compliance, replace risk analysis, or decide whether a disclosure or breach is lawful.

Tool	Purpose	Possible HIPAA support
CISO Assistant	GRC, risks, controls, evidence	Risk analysis, safeguard operation, evidence, or remediation
Wazuh	SIEM, endpoint monitoring, file integrity	Risk analysis, safeguard operation, evidence, or remediation
OpenSCAP	Linux configuration assessment	Risk analysis, safeguard operation, evidence, or remediation
Greenbone Community Edition	Vulnerability scanning	Risk analysis, safeguard operation, evidence, or remediation
osquery	Endpoint inventory and queries	Risk analysis, safeguard operation, evidence, or remediation
Trivy	Code, image, secret, and configuration scanning	Risk analysis, safeguard operation, evidence, or remediation
OWASP ZAP	Authorized web-application testing	Risk analysis, safeguard operation, evidence, or remediation
Keycloak	Identity, roles, authentication, MFA	Risk analysis, safeguard operation, evidence, or remediation
DefectDojo	Finding intake and remediation tracking	Risk analysis, safeguard operation, evidence, or remediation
Velociraptor	Endpoint visibility and incident response	Risk analysis, safeguard operation, evidence, or remediation
Open Policy Agent	Policy as code	Risk analysis, safeguard operation, evidence, or remediation

15.1 Tool-to-requirement verification matrix

Tool or resource	HIPAA support	Verification task	Output to retain	Important limitation
CISO Assistant	164.308(a)(1), 164.316, vendor and evidence governance	Map ePHI risks to safeguards, owners, evidence, findings, and treatment	Risk register, control matrix, approvals, audit trail	Records what users enter; does not prove source evidence is complete or accurate
HHS/ONC SRA Tool	164.308(a)(1)(ii)(A) risk analysis	Use structured questions to identify possible scope and control gaps	Completed assessment, supporting evidence, treatment actions	A starting aid; it does not guarantee an accurate and thorough enterprise risk analysis
osquery	164.308(a)(1), 164.310(d), 164.312(a) and (d)	Query endpoint users, software, encryption, services, and device state	Query, host list, timestamps, full results, reviewer decision	Coverage depends on installed and reporting endpoints and operating-system tables
Keycloak	164.308(a)(3)–(4), 164.312(a) and (d)	Test unique identity, roles, least privilege, MFA, emergency access, and removal	Configuration export, user and role population, test results, approvals	Only verifies systems using that identity platform; downstream authorization may differ

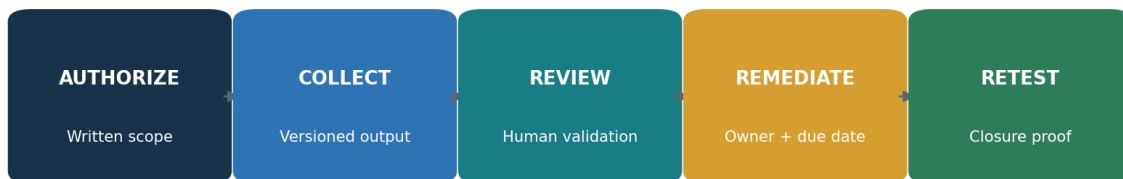
Tool or resource	HIPAA support	Verification task	Output to retain	Important limitation
Wazuh	164.308(a)(1)(ii)(D), 164.308(a)(6), 164.312(b)	Test log collection, alert generation, file integrity, review, investigation, and escalation	Agent inventory, rules, alert, review ticket, response and closure	An alert without documented human review and response does not prove the safeguard operates
OpenSCAP	164.308(a)(8), 164.312(a), 164.312(c)	Compare approved Linux hosts with a selected security baseline and retest correction	Profile, content version, host scope, HTML/ARF report, exception, rescan	Baseline compliance is not the same as HIPAA compliance and may affect applications
Greenbone	164.308(a)(1), 164.308(a)(8)	Measure authenticated vulnerability coverage, validate findings, track deadlines, and rescan	Target list, feed and scanner version, settings, report, tickets, rescan	Cannot find every weakness; scope, credentials, false positives, and fragile systems matter
Trivy	164.308(a)(1), 164.312(c), software and cloud risk	Scan pinned code, images, dependencies, secrets, and infrastructure configuration	Target digest, database and tool version, settings, result, ticket, retest	Results can contain secrets and may miss runtime, business-logic, and deployment risks
OWASP ZAP	164.308(a)(8), 164.312(c) and (e)	Passively review and, when authorized, actively test a laboratory or approved web application	Written scope, version, settings, findings, validation, correction, retest	Active scans can change data or interrupt care systems; automation is not a full penetration test
DefectDojo	164.308(a)(1), 164.308(a)(6), corrective-action evidence	Import findings, deduplicate, assign, track risk decisions, retest, and close	Finding history, owner, due date, evidence, risk acceptance, verified closure	Workflow status does not prove a fix; closure must be supported by independent retest
Velociraptor	164.308(a)(6), 164.312(b)	Collect approved endpoint artifacts during an isolated investigation and document chain of custody	Collection request, client scope, results, analyst notes, preservation record	Powerful collection can expose PHI or disrupt endpoints; use strict authorization and minimization
Open Policy Agent	164.308(a)(1), 164.312(a) and (c)	Test policy-as-code rules for required ownership, classification, encryption, or deployment conditions	Policy version, tests, allowed and denied inputs, pipeline decision, approval	Rules only cover encoded conditions; bad logic or missing integration creates false confidence

15.2 How to validate a tool before relying on it

- ✓ Approve the purpose, owner, systems, ePHI boundaries, data collected, hosting, support access, and retention.
- ✓ Verify the official software source, version, dependencies, release integrity, update process, and secure configuration.
- ✓ Create a known test condition and confirm the tool detects or blocks it as expected.
- ✓ Create a known allowed condition and confirm the tool does not create an unnecessary failure.
- ✓ Compare the tool's asset or agent population with an independent inventory and investigate missing coverage.
- ✓ Restrict administrative access, log changes, protect credentials, and test backup or recovery of the tool itself.
- ✓ Define human review, escalation, exception, correction, and retest procedures.
- ✓ Revalidate after major upgrades, configuration changes, new integrations, or material control failures.

15.3 Tool evidence package

- ✓ Written authorization and approved scope
- ✓ Architecture and data-flow note
- ✓ Tool, rule, feed, database, and content versions
- ✓ Configuration and service-account permissions
- ✓ Complete asset, agent, target, or repository population
- ✓ Raw and summarized results
- ✓ Reviewer identity, date, decision, and escalation
- ✓ Finding tickets, corrective action, risk acceptance, and due dates
- ✓ Retest and closure proof
- ✓ Known limitations and untested areas



Tool output becomes evidence only after scope, validation, action, and retest

Figure 7. From tool output to compliance evidence

15.4 CISO Assistant

GRC, risks, controls, evidence.

Official documentation and setup: [Open the official CISO Assistant guide](#)

Quick start

Create a fictional healthcare organization, add one ePHI risk, map a Security Rule safeguard, assign an owner, and attach sanitized evidence.

Evidence to retain

Record approval, purpose, owner, scope, systems, data classification, tool and content version, configuration, complete result, reviewer, decision, corrective action, and retest. Protect reports containing ePHI, credentials, architecture, identities, or vulnerabilities.

15.5 Wazuh

SIEM, endpoint monitoring, file integrity.

Official documentation and setup: [Open the official Wazuh guide](#)

Quick start

Connect one lab endpoint, create a harmless event, review the alert, and save the event, reviewer decision, and follow-up.

Evidence to retain

Record approval, purpose, owner, scope, systems, data classification, tool and content version, configuration, complete result, reviewer, decision, corrective action, and retest. Protect reports containing ePHI, credentials, architecture, identities, or vulnerabilities.

15.6 OpenSCAP

Linux configuration assessment.

Official documentation and setup: [Open the official OpenSCAP guide](#)

Quick start

Assess a laboratory Linux host against a suitable profile, export the report, fix one approved setting, and compare results.

Evidence to retain

Record approval, purpose, owner, scope, systems, data classification, tool and content version, configuration, complete result, reviewer, decision, corrective action, and retest. Protect reports containing ePHI, credentials, architecture, identities, or vulnerabilities.

15.7 Greenbone Community Edition

Vulnerability scanning.

Official documentation and setup: [Open the official Greenbone Community Edition guide](#)

Quick start

Scan only an approved lab target, validate one finding, correct it, rescan, and record scope, version, result, and reviewer.

Evidence to retain

Record approval, purpose, owner, scope, systems, data classification, tool and content version, configuration, complete result, reviewer, decision, corrective action, and retest. Protect reports containing ePHI, credentials, architecture, identities, or vulnerabilities.

15.8 osquery

Endpoint inventory and queries.

Official documentation and setup: [Open the official osquery guide](#)

Quick start

Query users, software, encryption, or processes on a lab endpoint and record the query, host, date, result, and review.

Evidence to retain

Record approval, purpose, owner, scope, systems, data classification, tool and content version, configuration, complete result, reviewer, decision, corrective action, and retest. Protect reports containing ePHI, credentials, architecture, identities, or vulnerabilities.

15.9 Trivy

Code, image, secret, and configuration scanning.

Official documentation and setup: [Open the official Trivy guide](#)

Quick start

Scan a pinned laboratory image or test repository, protect the report, validate one finding, fix it, and scan again.

Evidence to retain

Record approval, purpose, owner, scope, systems, data classification, tool and content version, configuration, complete result, reviewer, decision, corrective action, and retest. Protect reports containing ePHI, credentials, architecture, identities, or vulnerabilities.

15.10 OWASP ZAP

Authorized web-application testing.

Official documentation and setup: [Open the official OWASP ZAP guide](#)

Quick start

Proxy a local training application, start with passive analysis, validate one result, and export the scope and report.

Evidence to retain

Record approval, purpose, owner, scope, systems, data classification, tool and content version, configuration, complete result, reviewer, decision, corrective action, and retest. Protect reports containing ePHI, credentials, architecture, identities, or vulnerabilities.

15.11 Keycloak

Identity, roles, authentication, MFA.

Official documentation and setup: [Open the official Keycloak guide](#)

Quick start

Create a lab realm, roles, users, and MFA; test least privilege and export configuration and review evidence.

Evidence to retain

Record approval, purpose, owner, scope, systems, data classification, tool and content version, configuration, complete result, reviewer, decision, corrective action, and retest. Protect reports containing ePHI, credentials, architecture, identities, or vulnerabilities.

15.12 DefectDojo

Finding intake and remediation tracking.

Official documentation and setup: [Open the official DefectDojo guide](#)

Quick start

Import a lab scan, validate and assign one finding, record correction, retest it, and close it with evidence.

Evidence to retain

Record approval, purpose, owner, scope, systems, data classification, tool and content version, configuration, complete result, reviewer, decision, corrective action, and retest. Protect reports containing ePHI, credentials, architecture, identities, or vulnerabilities.

15.13 Velociraptor

Endpoint visibility and incident response.

Official documentation and setup: [Open the official Velociraptor guide](#)

Quick start

Use an isolated lab client, collect one harmless approved artifact, review the result, and record purpose, scope, and access.

Evidence to retain

Record approval, purpose, owner, scope, systems, data classification, tool and content version, configuration, complete result, reviewer, decision, corrective action, and retest. Protect reports containing ePHI, credentials, architecture, identities, or vulnerabilities.

15.14 Open Policy Agent

Policy as code.

Official documentation and setup: [Open the official Open Policy Agent guide](#)

Quick start

Write a lab rule that denies an ePHI resource without an owner or classification label; test allowed and denied inputs.

Evidence to retain

Record approval, purpose, owner, scope, systems, data classification, tool and content version, configuration, complete result, reviewer, decision, corrective action, and retest. Protect reports containing ePHI, credentials, architecture, identities, or vulnerabilities.

15.15 Free government resource

HHS/ONC Security Risk Assessment Tool: [Open the official SRA Tool page](#)

This free government resource can help small and medium practices begin a structured risk assessment. It does not guarantee compliance and does not replace a complete, organization-specific risk analysis.

15.16 Tool governance checklist

- ✓ Use only fictional or properly de-identified data in training.
- ✓ Obtain written authorization before scanning, monitoring, collection, or testing.
- ✓ Approve owner, scope, hosting, access, data handling, retention, and support location.
- ✓ Verify software sources, releases, dependencies, signatures, and update procedures.
- ✓ Use least privilege and protect service credentials and reports.
- ✓ Define who validates results, fixes findings, approves exceptions, and retests.
- ✓ Do not upload PHI or ePHI to any external service without approved legal, privacy, security, contract, and data-flow review.

16. Fictional Healthcare Laboratory and Portfolio

A complete practice environment using only synthetic information.

Harbor Light Health is a fictional outpatient clinic and health plan administrator. It uses an EHR, billing system, cloud email, patient portal, medical devices, remote support, and several business associates. Every person, record, address, claim, diagnosis, and identifier in the laboratory is invented.

Project 1 — Scope and roles

Document covered-entity functions, business associates, hybrid boundaries, PHI, ePHI, systems, and data flows.

Project 2 — Risk analysis

Create a system inventory, threat and vulnerability register, risk method, findings, and treatment plan.

Project 3 — Security safeguards

Build a Security Rule matrix with owners, implementation choices, evidence, exceptions, and retests.

Project 4 — Privacy rights

Complete fictional access, amendment, confidential-communication, and accounting requests.

Project 5 — Breach

Assess a misdirected billing export using the four factors and prepare notification decisions.

Project 6 — Vendor

Review a fictional cloud BA, contract terms, subprocessors, security evidence, incident duties, and exit plan.

Project 7 — Tools

Use three Chapter 15 tools in an isolated lab and document scope, limitations, findings, correction, and retest.

16.1 Portfolio ethics

Never publish real patient, member, employee, provider, or claim information.

Label each file as fictional training work.

Do not copy a company's confidential risk analysis, BAA, incident, or architecture.

Remove usernames, paths, hostnames, tokens, keys, IP addresses, and hidden metadata before publication.

Explain assumptions and where legal, privacy, clinical, or security review is required.

17. Thirty-Day Learning Plan

A realistic month of official reading, practice, portfolio work, and interview preparation.

Week	Focus	Required output
Week 1	Scope, roles, PHI/ePHI, Privacy Rule	Scope memo, data map, use/disclosure examples
Week 2	Security Rule and risk analysis	Asset inventory, risk register, safeguard matrix
Week 3	Rights, breach, vendors, Part 2	Rights file, breach assessment, vendor review
Week 4	Tools, portfolio, interview	Sanitized portfolio and practiced answers

17.1 Daily habit

Read one current HHS, eCFR, or NIST section.

Explain one requirement in your own words.

Create one fictional evidence item.

Review it for completeness, sensitivity, and dates.

Add one correction or lesson to the portfolio.

18. Interview Preparation

Questions and short answers for analysts and managers.

Who must comply with HIPAA?

Covered entities, business associates, and certain related arrangements. Covered entities include health plans, clearinghouses, and qualifying providers that conduct covered electronic transactions.

What is PHI?

Individually identifiable health information held or transmitted by a covered entity or business associate, subject to regulatory exclusions.

PHI versus ePHI?

PHI may be electronic, paper, or oral. ePHI is PHI maintained or transmitted electronically and is the focus of the Security Rule.

What is minimum necessary?

When applicable, limit PHI use, disclosure, and requests to what is reasonably necessary for the purpose.

What is a HIPAA risk analysis?

An accurate and thorough assessment of potential risks and vulnerabilities to the confidentiality, integrity, and availability of all ePHI held by the regulated entity.

Does addressable mean optional?

No. Assess the specification and implement it if reasonable and appropriate. Otherwise document the decision and use an equivalent alternative when reasonable and appropriate.

What is the breach standard?

An impermissible use or disclosure is presumed a breach unless a documented four-factor assessment shows a low probability that PHI was compromised or an exception applies.

How do business associates support compliance?

They follow BAAs and applicable HIPAA duties, protect ePHI, manage subcontractors, report incidents and breaches, support rights, and return or destroy PHI as required.

How do you prove a safeguard works?

Use complete, dated evidence connecting scope, risk, requirement, implementation, owner, review, exception, corrective action, and retest.

18.1 Manager's 60-second answer

Interview response: I treat HIPAA as an operating program, not a policy binder. I define regulated roles and ePHI scope, perform ongoing risk analysis, implement administrative, physical, and technical safeguards, manage access and vendors, make privacy rights work, assess incidents promptly, and require reliable evidence. Management owns resources and risk decisions while privacy, legal, security, clinical, and compliance teams provide specialized review.

19. Templates and Checklists

Practical structures for an approved organizational system.

19.1 ePHI inventory fields

System, application, device, interface, repository, media, or service
 Business and technical owner
 Covered entity or business associate role
 ePHI types, volume, people, purpose, and criticality
 Users, privileged access, and authentication
 Location, hosting, remote support, and data flow
 Encryption, logging, backup, recovery, retention, and disposal
 Vendor, BAA, subcontractors, and incident contact
 Last review, change trigger, and next review

19.2 Risk register fields

Asset and ePHI scope
 Threat, vulnerability, and existing safeguard
 Likelihood and impact
 Risk rating and method
 Treatment, owner, resources, and date
 Residual risk and acceptance authority
 Exception expiry
 Validation and retest evidence

19.3 Breach fact sheet

Field	Required information
Discovery	Who discovered it, when, and when the entity became aware
Incident	What happened, systems, accounts, location, containment
PHI	Nature, sensitivity, identifiers, people, amount, likelihood of re-identification
Recipient	Who received or accessed it and their obligations
Acquisition	Whether PHI was actually acquired or viewed
Mitigation	Retrieval, deletion, assurances, account actions, monitoring
Decision	Exception or low-probability analysis, notices, approvers
Action	Correction, sanctions, training, testing, lessons

19.4 BAA checklist

Roles and services correct
 Permitted and required use/disclosure defined
 Safeguards and Security Rule duties
 Incident and breach reporting timing and content
 Subcontractor flow-down

Rights and accounting support
HHS access
Return/destruction and infeasibility handling
Termination rights
Contacts, locations, changes, and review cadence

19.5 Manager pre-audit checklist

Scope and organizational roles approved
Complete ePHI inventory and data-flow map
Current accurate and thorough risk analysis
Risk treatment with evidence and retests
Safeguard implementation decisions documented
Access, activity review, training, backup, and incident samples complete
BAA population and monitoring complete
Privacy rights and disclosure evidence complete
Breach log and HHS reports reconciled
Policies current and required documentation retained six years

20. Glossary

Plain-English definitions of important HIPAA and healthcare privacy terms.

Addressable implementation specification. A Security Rule specification that must be assessed and implemented when reasonable and appropriate, or replaced by a documented equivalent alternative when appropriate.

Authorization. A written permission meeting the Privacy Rule's required elements and statements.

Breach. An impermissible acquisition, access, use, or disclosure that compromises PHI security or privacy, subject to the rule's presumption, risk assessment, and exceptions.

Business associate. A person or organization performing certain functions or services involving PHI for a covered entity.

Covered entity. A health plan, health care clearinghouse, or qualifying health care provider under HIPAA.

Designated record set. Records maintained by or for a covered entity that determine or document specified health, claims, payment, or case-management information and support access rights.

ePHI. Protected health information maintained or transmitted electronically.

Health care operations. Defined operational activities such as quality, competency, underwriting limits, auditing, planning, and management functions.

HITECH Act. A federal law that expanded health-information technology, breach, business associate, and HIPAA enforcement provisions.

Minimum necessary. A requirement, when applicable, to limit PHI use, disclosure, and requests to what is reasonably needed.

Part 2. The federal confidentiality rules for records of federally assisted substance use disorder programs under 42 CFR Part 2.

PHI. Individually identifiable health information protected by HIPAA when held or transmitted by a covered entity or business associate, subject to exclusions.

Privacy Rule. The HIPAA standards for PHI use, disclosure, individual rights, and privacy administration.

Required implementation specification. A Security Rule implementation specification that must be implemented.

Risk analysis. An accurate and thorough assessment of risks and vulnerabilities to all ePHI.

Risk management. Security measures that reduce identified risks and vulnerabilities to a reasonable and appropriate level.

Security Rule. The HIPAA standards protecting ePHI through administrative, physical, and technical safeguards.

Treatment, payment, and health care operations. Core categories for permitted PHI use and disclosure under the rule.

Unsecured PHI. PHI not rendered unusable, unreadable, or indecipherable through technology or methodology specified by HHS.

21. Subject Index

An alphabetical guide to major topics. References point to sections so the index remains useful after editing.

Topic	Sections	Topic	Sections
Access right	4, 12.2, 19	Notice of privacy practices	4, 10, 12.2
Addressable	5.2, 20	Open-source tools	15
Administrative safeguards	6, 12.1	Part 2	10
Authorization	3.3, 12.2	PHI	2.3, 20
Breach	8, 12.3, 19.3	Physical safeguards	7, 12.1
Business associate	2.2, 9, 19.4	Privacy Rule	3–4, 12.2
De-identification	2.4, 3.5	Reproductive health	10.3
ePHI	2.3, 5–7	Risk analysis	5.3, 6, 12.1
Enforcement	11, 12.4	Security incident	6, 8
HIPAA Security Rule NPRM	1.3, 11.4	State law	10.2, 11.3
Individual rights	4	Technical safeguards	7, 12.1
Junior analyst	14, 16–18	Vendor oversight	9, 13
Minimum necessary	3.4, 12.2	Workforce training	6, 12.1

22. Official References and Further Study

Current government law, guidance, tools, and official project documentation used for verification.

[eCFR — 45 CFR Part 160](#)

[eCFR — 45 CFR Part 164](#)

[HHS — HIPAA for Professionals](#)

[HHS — Privacy Rule](#)

[HHS — Security Rule](#)

[HHS — Breach Notification Rule](#)

[HHS — Risk Analysis Guidance](#)

[HHS — HIPAA Audit Protocol](#)

[HHS — Business Associate Agreement Provisions](#)

[HHS — 42 CFR Part 2](#)

[HHS — Reproductive Health Rule Status](#)

[HHS — Security Rule NPRM](#)

[NIST SP 800-66 Rev. 2](#)

[HealthIT.gov — Security Risk Assessment Tool](#)

[CISO Assistant documentation](#)

[Wazuh documentation](#)

[OpenSCAP documentation](#)

[Greenbone Community Edition documentation](#)

[osquery documentation](#)

[Trivy documentation](#)

[OWASP ZAP documentation](#)

[Keycloak documentation](#)

[DefectDojo documentation](#)

[Velociraptor documentation](#)

[Open Policy Agent documentation](#)

Final reminder: Regulations, court decisions, guidance, penalty amounts, technology, and facts change. Verify the current eCFR, HHS and NIST sources, state law, Part 2 status, and qualified legal advice before acting on a real matter.